

ARHIA v11.1 — Master Architecture

English master architecture and deployment reference for governed Agentic Process Automation

Version: 11.1 (Remediation Release)

Audience: Global CIOs, CISOs, enterprise architects, procurement, audit and implementation teams

Classification: Confidential / Controlled use

Purpose: Provide the English-only master architecture, operating model and deployment reference for ARHIA.

Change log v11.1: Added MAESTRO crosswalk, corrected OWASP ASI taxonomy, cited Singapore CSA Addendum, added reading-order guide, added sequence diagram references, expanded design-principle rationale. v11.1.1: Added Annexes I (Incident management) and J (Data classification and zoned execution) to annex register. ATK reference implementation upgraded to v2.1 with OPA integration, all 6 decision outcomes, AIBOM validation per Annex K.2, and HMAC-signed ledger.

How to read the ARHIA document set

The ARHIA master set comprises five tiers of documentation designed for different audiences. Readers should begin at the tier that matches their role and depth of engagement:

- Tier 1 — Framework Overview (v1.8): Market-facing executive summary. Read first if you are a CIO, board member, investor, or transformation leader who needs the strategic rationale and competitive positioning in under 20 minutes.
- Tier 2 — Master Architecture (this document, v11.1): Normative specification. Read second if you are an enterprise architect, CISO, procurement lead, or audit team member who needs to evaluate the deployable architecture, trust model, SLAs, and control contracts.
- Tier 3 — Annex Compendium (v11.1): Detailed technical profiles. Read selectively when you need implementation-grade specifications for specific controls (AIBOM, XAI, OPA/Rego, MCP dual-path, HA/DR, etc.).
- Tier 4 — ATK Reference Implementation Pack (v2.0): Engineering proof. Read if you need to verify that the trust nucleus is demonstrable in code, run the FastAPI service, or prepare a customer-facing demonstration.
- Tier 5 — Enterprise Pilot Playbook (v2.0): Operational execution. Read when you are ready to plan and execute the first governed production pilot, including RACI, timeline, drill scripts, and evidence templates.

1. Executive summary

ARHIA v11.1 is the remediation release of the English master set for global review, procurement and implementation. It defines ARHIA as the operating reference architecture that turns governance frameworks, risk taxonomies and interoperability protocols into a deployable enterprise APA system. This release standardizes English as the authoritative language, introduces a demonstrable ATK reference implementation with a runnable FastAPI service, and adds a fully operationalized enterprise pilot playbook so the architecture is not only auditable on paper but executable in practice.

Version 11.1 specifically addresses the findings of an independent architecture review conducted in March 2026: the landscape crosswalk now includes CSA MAESTRO (February 2025) and the Singapore CSA Addendum on Securing Agentic AI (October 2025); the OWASP Agentic Top 10 crosswalk has been corrected to the official ASI01–ASI10 taxonomy published in December 2025; the ATK reference implementation has been upgraded from a demonstration script to a FastAPI service with OPA integration and JWT capability tokens; and the Enterprise Pilot Playbook has been expanded from an outline to a full operational manual with RACI, timeline, drill scripts, and evidence templates.

2. Why ARHIA exists in the 2026 landscape

Frameworks now define trust maturity, threat taxonomies and interoperability expectations, but enterprises still lack the operating layer that decides whether an agent may act, how tool use is governed, where classified data may execute, how evidence is retained, and how humans intervene without collapsing productivity. ARHIA fills that operational gap.

As of March 2026, the landscape has matured significantly. CSA published the Agentic Trust Framework with a five-question maturity model and explicit promotion gates. OWASP released the Top 10 for Agentic Applications (December 2025) with the ASI01–ASI10 taxonomy. CSA’s MAESTRO framework (February 2025) provides a seven-layer threat modeling methodology specifically designed for agentic AI. Singapore’s CSA published a draft Addendum on Securing Agentic AI (October 2025) with capability-based risk framing. NIST is developing AI control overlays for SP 800-53 with first public drafts expected in 2026. MCP has become the de facto interoperability protocol for tool use. ARHIA operationalizes all of these across heterogeneous models, agent runtimes and RPA platforms.

3. Landscape crosswalk

ARHIA does not replace CSA ATF, CSA MAESTRO, OWASP Agentic Top 10, NIST initiatives, the Singapore CSA Addendum on Securing Agentic AI, or MCP. It operationalizes them across heterogeneous models, agent runtimes and RPA platforms.

External reference	What it contributes	Gap left by itself	ARHIA role
CSA ATF (2026)	Trust maturity model with five-question	No execution plane, no zoned data	Implements trust with ATK, tokens, A0–A4 autonomy and

	governance and promotion gates for agents	residence, no operating model	zoned execution; promotion gates map to ATK evidence requirements
CSA MAESTRO (Feb 2025)	Seven-layer threat modeling framework for agentic AI (Foundation Models through Agent Ecosystem)	No deployable runtime controls; threat model only, not operating architecture	Maps MAESTRO layers to ARHIA planes: Layers 1–3 governed by Trust Plane, Layer 4 by zoned execution, Layers 5–6 by Observability Fabric and policy-as-code, Layer 7 by MCP governance and workbench
OWASP Agentic Top 10 (Dec 2025)	Threat taxonomy ASI01–ASI10 for agentic systems, validated by 100+ experts including NIST and Alan Turing Institute	No deployable architecture or runtime controls	Translates each ASI risk into specific ARHIA controls, gates, evidence and testing (see Annex B)
NIST AI RMF / SP 800-53 overlays	Principles, assurance expectations, and AI-specific control overlays (drafts expected 2026)	No deployment blueprint	Maps principles to concrete components, evidence obligations and Core-M0 requirements
Singapore CSA Addendum on Securing Agentic AI (Oct 2025)	Capability-based risk framing, workflow mapping for autonomy risks, human-in-the-loop controls, scenario-based testing	No reference architecture or runtime governance	Implements capability-based risk as ATK classification envelopes; workflow mapping as composition contracts; HITL as workbench; scenario testing as pilot drill scripts
AAIF / MCP	Interoperable tool protocol for agent-to-tool communication	No governance layer around protocol	Adds dual-path interception (synchronous auth, asynchronous analytics), delegated auth, evidence continuity and return-path classification

4. Business value translation

ARHIA is adopted for controlled outcomes: lower incident exposure, faster cycle times, faster audit readiness, and a predictable path from pilot to regulated go-live.

Business driver	ARHIA mechanism	Expected result
Cycle-time compression	Multi-agent composition + workbench + governed autonomy	Faster completion with bounded risk
Incident cost avoidance	ATK, no-egress, MCP dual path, ledger	Lower likelihood and blast radius of incidents

Compliance acceleration	AIBOM, explanation records, policy-as-code, testing	Faster audit readiness
Time-to-value	Core-M0 + reference implementation + pilot playbook	Predictable path to go-live
Regulatory alignment	MAESTRO layer mapping + Singapore addendum controls + OWASP ASI mitigations	Evidence-backed alignment with emerging global standards

5. Design principles

Six non-negotiable principles govern every ARHIA design decision. Each principle exists because of specific failure patterns observed in early agentic deployments:

Principle 1 — Trust is authorized per micro-action. Session-level trust tokens are insufficient for agentic systems because an agent's risk profile changes with every action it takes. A payroll agent that reads employee records (low risk) and then initiates a wire transfer (high risk) cannot operate under a single blanket authorization. The ATK evaluates every material action independently with full context.

Principle 2 — Composition is typed and explicit. Ad-hoc agent chaining produces unpredictable behavior and makes post-incident analysis impossible. Every handoff between agents is governed by a typed composition contract that declares identity, context sharing rules, input/output schemas, fallback paths and evidence expectations.

Principle 3 — Data class governs zone and egress. Data sensitivity determines where a capability may execute, not the other way around. High-sensitivity workloads remain on local models in trusted zones; lower-risk workloads can use external frontier models under masked egress. This prevents data leakage by architecture rather than by policy alone.

Principle 4 — Observability is a first-class contract. Observability is not a debugging convenience; it is a mandatory evidence obligation. OpenTelemetry instrumentation, trace propagation and evidence retention are contractual requirements, not optional add-ons.

Principle 5 — Learning is governed and versioned. Corrections, incidents and regression findings are never applied directly to production. They flow through a governed learning loop that produces versioned change packages, updates AIBOM records when behavior changes materially, and routes all changes through formal Architecture Board review windows.

Principle 6 — Humans are bounded control actors with curated evidence. Human-in-the-loop is not a raw data dump. The workbench presents curated evidence, structured decision surfaces and bounded actions (approve, reject, revise, escalate, quarantine), so that human decisions are informed, consistent and auditable.

6. Executive architecture

The architecture below summarizes the deployable logic: business request → ATK evaluation → capability token issuance → governed execution, with MCP dual-path semantics and evidence continuity across all three planes.

[Figure 1. Executive architecture view — Request to Token to Execution. See corresponding diagram.]

The critical flow sequence is: (1) Business request arrives with identity, action, data, runtime and policy envelopes. (2) ATK evaluates all envelopes against OPA/Rego policy bundles and AIBOM trust status. (3) If approved, ATK issues an ephemeral JWT capability token with constraints (scope, TTL, audience, zone). (4) Token is presented to the MCP interceptor, which performs synchronous authorization. (5) Authorized MCP call proceeds to the target tool/API.

(6) Asynchronous evidence path enriches the ledger with trace, outcome and classification data. (7) Immutable decision ledger records the complete evidence chain. (8) If human approval is required, the workbench surfaces curated evidence and holds the token until a decision is made.

7. Three-plane deployable realization

Trust Plane decides, Control Plane coordinates, Execution Plane performs. Each plane has concrete services, interfaces, persistence boundaries and failure behavior.

Plane	Core services	Primary interfaces	State / persistence	Typical deployment	Failure mode	Degradation mode
Trust Plane	ATK, policy engine, token issuer, residency guard, risk evaluator, AIBOM validator	REST/gRPC, OPA decision API, token validation	Policies, trust state, token log, AIBOM inventory	Trusted on-prem / private cloud	Decision service unavailable	Deny-by-default for critical actions; short-TTL safe cache for low-risk repeats
Control Plane	State orchestrator, case manager, trace correlator, exception manager, learning intake	Event bus, APIs, workflow state APIs	Case state, workflow state, escalation state	Private cloud / regulated VPC	Loss of orchestration continuity	Persistent queue, replay, hold-and-review, human takeover
Execution Plane	Agents, RPA bots, MCP clients, connectors, APIs, workbench UI	MCP, APIs, RPA runtimes, workbench actions	Task results, transient context, tool receipts	Distributed by zone and capability	Tool/runtime failure	Fallback human, bypass, rollback, retry with bounded policy

8. Agentic Trust Kernel operational specification

The ATK evaluates a micro-action using five input envelopes and produces one of six decision outcomes. Each decision has a concrete operational effect.

ATK input	Description
identity envelope	actor_id, tenant, environment, capability_id, role attributes
action envelope	requested capability, target resource and operation
data envelope	classification ceiling, zone, expected output class, egress requirements
runtime envelope	trace_id, case_id, autonomy level requested, drift state, trust signals
policy / supply chain envelope	policy bundle version, AIBOM reference and model trust status

ATK decision	Operational effect
allow	Issue ephemeral JWT capability token with constraints (scope, TTL, audience, zone restrictions)
allow_with_restrictions	Token with reduced scope, shorter TTL or mandatory masking
require_human_approval	Route to workbench; token withheld until human decision
deny	No execution; reason code, explanation record and evidence recorded to ledger
degrade_autonomy	Reduce effective autonomy level before proceeding; notify Control Plane
quarantine_actor	Immediate containment, hot token revocation, incident record created

ATK latency SLAs

Metric	Objective	Alert threshold	Behavior when breached
ATK decision latency p95	<= 150 ms	> 250 ms	critical: deny-by-default; non-critical: bounded safe cache
Token issuance p95	<= 50 ms	> 100 ms	hold action, log degraded path
OPA evaluation p95	<= 40 ms	> 80 ms	switch to warmed local bundle cache where allowed
AIBOM lookup p95	<= 25 ms	> 60 ms	high-risk models blocked until trust check succeeds

9. Formal multi-agent composition

Composition is typed and explicit: sequential, conditional, parallel, delegated-with-return and human escalation patterns. Every handoff is independently re-authorized by the ATK.

Composition contracts enforce the following minimum artifacts:

Composition artifact	Minimum contract
Identity envelope	agent_id, capability_id, tenant, environment, trust level
Case context	case_id, trace_id, SLA class, classification ceiling, expected outcome
Shared context declaration	what may be shared, what must be masked, retention policy
Input / output schema	typed contract for produced and consumed artifacts
Fallback path	retry, bypass, rollback or workbench handoff
Evidence expectation	receipts, explanation record, telemetry and ledger pointer

10. Formal autonomy scale

ARHIA uses A0–A4 autonomy levels, scoped by capability, domain, data class and zone.

Promotion is evidence-based; degradation is automatic when trust weakens.

Level	Name	Permitted action	Promotion gate
A0	Suggestion only	Recommend only	N/A
A1	Copilot with approval	Prepare actions for human review	Low policy incidents and useful recommendations over evaluation period
A2	Supervised execution	Execute bounded actions with monitoring	Stable trust score, low override rate, clean operational history
A3	Autonomous with audit	Autonomous within bounded domain	Evidence trail, successful drills, Architecture Board approval
A4	Restricted full autonomy	Highest bounded autonomy	Exceptional evidence, executive approval, continuous behavioral monitoring

11. Observability Fabric

OpenTelemetry is mandatory. A single trace_id links trust decision, workflow handoff, MCP invocation, workbench action and ledger receipt.

Aspect	ARHIA requirement
Instrumentation standard	OpenTelemetry for traces, metrics and logs
Trace propagation	trace_id created or validated by ATK and propagated across all three planes

Minimum dashboards	plane latency and saturation, allow/deny/degrade ratios, MCP outcomes, workbench SLA, drift indicators and rollback frequency
Retention baseline	operational telemetry 30–90 days; security/MCP evidence 180 days; ledger and explanation records per legal retention schedule
Failure handling	if telemetry degrades, critical actions proceed only if trust and evidence minimums still hold; otherwise hold-and-review

12. Human Workbench

The workbench surfaces curated evidence, not raw payloads. Humans approve, reject, revise, escalate or quarantine; their corrections feed the governed learning loop.

Workbench capability	Operational behavior
Decision surfaces	approve, reject, revise, escalate, quarantine
Evidence shown	reason code, explanation record, classification, expected effect, trace pointer, prior similar cases
SLA handling	hold, reroute or emergency fallback when response breaches threshold
Learning capture	corrections become governed learning intake, never direct production mutation

13. Governed Learning Loop

The loop turns corrections, incidents and regression findings into versioned change packages. It never patches production in place and it updates AIBOM records when behavior changes materially. All change packages route through the Architecture Board before deployment.

14. MCP as interoperability strategy

MCP is the preferred tool-use protocol. The interceptor operates in dual path: synchronous for authorization and high-risk return-path checks, asynchronous for extended analytics and evidence. See Annex N for the complete MCP dual-path runtime profile with sequence diagrams and timing analysis.

15. Data classification, zoning and Core-M0 sizing

Data class governs where capabilities may run and what egress is allowed. Core-M0 is the minimum contractual scope for a first regulated go-live.

[Figure 2. Core-M0 sizing and cost drivers.]

Cost driver	Primary variable	Impact on setup	Impact on recurring opex
-------------	------------------	-----------------	--------------------------

Event bus volume	Daily events, peaks, retries	Bus, storage and monitoring baseline	Throughput, storage and telemetry cost
Capabilities in production	Number of governed use cases	Integration and policy authoring effort	Support, monitoring and regression-test footprint
Zone complexity	On-prem vs private cloud vs external cloud mix	Network and security complexity	Ongoing infra and ops cost by zone
Inference mix	Local SLMs vs external frontier models	Model hosting or connector setup	GPU/CPU cost or external token cost
Evidence retention	Ledger, telemetry and MCP evidence periods	Storage architecture choices	Long-tail storage and compliance cost

16. English-only master set, reference implementation and first pilot

English is the authoritative language of the master set. ARHIA now includes a FastAPI-based ATK reference implementation with OPA sidecar integration and JWT capability tokens, and a fully operationalized enterprise pilot playbook with RACI, week-by-week timeline, drill scripts, and evidence templates.

Design principles (normative)

- Trust is never presumed; every material action is authorized with context and evidence.
- Composition is typed and explicit.
- Data class governs zone, egress and effective autonomy.
- Observability is mandatory.
- Learning is governed and versioned.
- Humans are bounded control actors with curated evidence.

Annex register

- Annex A — Landscape crosswalk (CSA ATF, MAESTRO, OWASP, NIST, Singapore, MCP)
- Annex B — Threat model, OWASP Agentic Top 10 (ASI01–ASI10) crosswalk, and MAESTRO layer mapping
- Annex C — Multi-agent composition contract
- Annex D — Formal autonomy scale (A0–A4)
- Annex E — Observability Fabric
- Annex F — Human Workbench contract
- Annex G — Governed Learning Loop
- Annex H — MCP interoperability profile
- Annex I — Incident management and escalation profile
- Annex J — Data classification and zoned execution profile
- Annex K — AIBOM profile and model supply-chain assurance
- Annex L — Explanation record / XAI profile
- Annex M — OPA/Rego policy bundle profile and test harness
- Annex N — MCP dual-path runtime profile
- Annex O — ATK reference implementation contract
- Annex P — First enterprise pilot playbook
- Annex Q — High availability, disaster recovery, RPO / RTO profile
- Annex R — Procurement and cost support artifacts

End of ARHIA v11.1 Master Architecture.